

Zero Trust Network Access (ZTNA) with Zscaler: Preventing Unauthorized Application Access

S.NO	NAME	COLLEGE NAME	CONTACT
1	PANDISWARI C	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs237pandiswaric@skacas.ac.in
2	BHARATH KUMAR R	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs204bharathkumarr@skacas.ac.in
3	AATHISWARAN M	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs201aathiswaranm@skacas.ac.in
4	MARI S	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs230maris@skacas.a.in
5	RENI S	SRI KRISHNA ADITHYA COLLEGE OF ARTS AND SCIENCE	23bscs242reniss@skacas.ac.in

Project details

Title: Zero Trust Network Access (ZTNA) with Zscaler: Preventing Unauthorized Application Access

- **AI-Enhanced User Protection (AIUP)**

Zero Trust Network Access (ZTNA) with Zscaler is a modern security approach that ensures only authorized users can access organizational applications and resources. Unlike traditional security models that trust users once they enter the network, ZTNA follows the principle of “never trust, always verify.” Every user and device must be authenticated and validated before being allowed to connect to an application.

ZTNA with Zscaler works by creating a secure connection between the user and the specific application instead of giving full network access. This approach minimizes the risk of cyber threats by ensuring that unauthorized users, compromised devices, or attackers cannot access sensitive applications. By continuously verifying user identity, device status, and access permissions, ZTNA helps organizations maintain strong protection against modern cyber threats.

This system is essential for today’s digital environment where employees access applications from remote locations and different devices. With increasing cyberattacks such as phishing, credential theft, and unauthorized access attempts, ZTNA with Zscaler provides a secure way to protect applications. It helps organizations prevent data breaches, reduce security risks, and ensure that only trusted users can interact with critical systems and resources.

Abstract:

The growing number of cyber threats and the limitations of traditional security models, such as VPN-based access, require a more advanced approach to protecting organizational applications. Traditional systems often provide broad network access once a user is authenticated, which can lead to security risks such as unauthorized access and lateral movement within the network. To address these challenges, this project focuses on implementing Zero Trust Network Access (ZTNA) using Zscaler to ensure secure and controlled access to applications.

The project demonstrates how ZTNA can replace traditional network-level access with application-specific, identity-based connectivity, ensuring that users can only access the resources they are authorized to use. By using cloud-based security architecture, Zscaler acts as a secure broker between users and applications, verifying identity, device status, and access permissions before establishing a connection. This approach helps protect sensitive applications by making them invisible to unauthorized users and reducing the risk of cyberattacks.

Additionally, the system can be integrated with identity management platforms and security monitoring tools to improve authentication, logging, and threat detection. This enables organizations to maintain strong security policies, monitor user activity, and quickly respond to potential threats. Overall, the implementation of ZTNA with Zscaler provides a scalable and efficient security framework that prevents unauthorized application access, enhances data protection, and supports secure access for modern remote and mobile users.

Use Case Scenarios:

Scenario 1: Secure Remote Access to Organizational Application

An employee working from home needs to access the organization's internal application to complete their work tasks. Using Zero Trust Network Access (ZTNA) provided by Zscaler, the employee can securely connect to the required application without gaining full access to the internal network. The system first verifies the user's identity through the organization's identity provider and checks the security status of the device before allowing access.

Once authentication and verification are successful, Zscaler establishes a secure connection only to the specific application required by the user. This ensures that unauthorized users cannot access other internal systems or sensitive data. By limiting access to only the necessary resources, ZTNA helps prevent cyber threats and protects organizational applications from unauthorized access.

Output:

- User identity successfully verified
- Device security posture validated (antivirus active, system updated)
- Secure connection established only to the authorized application
- Internal network and other applications remain hidden from the user

Scenario 2: External User Accessing a Specific Application

An external collaborator or partner requires temporary access to a specific application hosted within an organization. Using Zero Trust Network Access (ZTNA) provided by Zscaler, the administrator creates a temporary, application-specific access policy. This policy allows the external user to connect only to the authorized application without exposing the entire internal network.

Before granting access, the system verifies the user's identity and ensures that the access request follows the defined security policies. Once verified, Zscaler establishes a secure connection only to the permitted application. This approach ensures that external users can perform their tasks safely while preventing unauthorized visibility into other internal systems.

Output:

- External user identity successfully verified
- Access policy enforced (time-limited access to a specific application only)
- Internal servers and applications remain hidden from public internet scans
- Session automatically ends when the access period expires

Scenario 3: Secure Student Access to Online Examination Application

During online examinations, a large number of students access the institution's examination application from different locations at the same time. Using Zero Trust Network Access (ZTNA) implemented through Zscaler, only authenticated students are allowed to access the examination system. Before granting access, the system verifies the student's identity and ensures that the request follows the defined security policies.

Once verified, ZTNA creates a secure connection only to the examination application instead of giving access to the entire internal network. This helps protect other sensitive systems, such as student records or grading databases, from unauthorized access. By using cloud-based security and strict access control, the system can handle thousands of users while maintaining strong protection against cyber threats.

Output:

- Large number of users authenticated securely through cloud-based verification
- Each student connected only to the authorized examination application
- Access to other internal systems such as databases or servers is blocked
- Examination server details remain hidden from the public internet

Scenario 4: IT Administrator Performing Secure Server Maintenance

An IT administrator needs to perform maintenance and updates on an internal application server. Instead of using traditional VPN access that provides full network connectivity, the administrator connects using Zero Trust Network Access (ZTNA) implemented through Zscaler. The system first verifies the administrator's identity using strong authentication methods before granting access.

After successful verification, ZTNA establishes a secure connection only to the specific server management interface required for maintenance. The administrator does not receive access to the entire network, which helps prevent misuse or accidental access to other systems.

Additionally, the session can be monitored to ensure that all activities follow the organization's security policies.

This approach helps organizations maintain strict access control while allowing administrators to perform necessary tasks safely and efficiently.

Output:

- Administrator identity verified using multi-factor authentication
- Secure connection established only to the authorized server management interface
- Administrative activities monitored and logged for auditing purposes
- Any attempt to access other servers or resources is automatically blocked

Scenario 5: Temporary Contractor Access to a Specific Application

During a system upgrade or maintenance project, an organization may hire a temporary contractor who needs access to a specific internal application or file server. Using Zero Trust Network Access (ZTNA) implemented through Zscaler, the contractor can be given limited and temporary access only to the required resource.

Instead of providing full network access or permanent system credentials, the administrator creates a restricted, application-specific access policy. The contractor's identity is verified through the organization's authentication system before access is granted. Once verified, ZTNA establishes a secure connection only to the required file server or application needed for the migration task.

This approach ensures that contractors can complete their work while the organization's internal network and other systems remain protected from unauthorized access.

Output:

- Contractor identity successfully verified through the authentication system
- Access granted only to the authorized file server or migration application
- All user activities such as file transfers are securely logged for monitoring
- Access permissions automatically revoked after the project completion period

Stage-1

Title Of the Project: -

Zero Trust Network Access (ZTNA) with Zscaler: Preventing Unauthorized Application Access

Overview:

The project focuses on implementing Zero Trust Network Access (ZTNA) using the cloud security platform Zscaler to prevent unauthorized access to organizational applications. In traditional network security models, users inside the corporate network are often trusted automatically once they log in. However, this approach can expose the organization to various cyber threats such as data breaches, unauthorized access, and insider attacks. To overcome these limitations, modern organizations are adopting the Zero Trust security model, which follows the principle of “never trust, always verify.”

Zero Trust Network Access ensures that every user and device attempting to access an application must be verified and authenticated before access is granted. Instead of giving users complete access to the internal network, ZTNA provides application-level access, meaning users can only access the specific applications they are authorized to use. This reduces the risk of attackers moving within the network and accessing sensitive information.

The system works by verifying the user’s identity, checking the security status of the device, and evaluating security policies before allowing access to any application. Authentication can be performed through identity providers using methods such as passwords, multi-factor authentication, or single sign-on systems. In addition, the device posture is also evaluated to ensure that the device meets the required security standards, such as updated operating systems, antivirus protection, and secure configurations.

Once the authentication and device verification processes are completed successfully, the Zscaler cloud platform establishes a secure connection between the user and the requested application. This connection is created through encrypted tunnels, ensuring that sensitive data remains protected during communication. Since applications are not directly exposed to the internet or internal network, the attack surface is significantly reduced.

Another important feature of ZTNA with Zscaler is continuous monitoring and policy enforcement. The system constantly evaluates user behavior, connection requests, and security conditions in real time. If any suspicious activity, unusual access pattern, or policy violation is detected, the system can immediately block access or require additional verification steps. This helps in preventing unauthorized application access and protecting organizational resources.

The solution also supports remote and mobile users, which is especially important in modern work environments where employees frequently work from home or different locations. ZTNA enables secure access to applications without requiring traditional VPN connections, improving both security and user experience. Since the platform is cloud-based, it provides scalability and flexibility to support growing numbers of users and applications.

Furthermore, the system includes features such as security monitoring, reporting, and compliance management. Administrators can track user activity, monitor access requests, and generate security reports to maintain transparency and accountability. Data protection is ensured through encryption, secure authentication, and strict access control policies.

Overall, the implementation of Zero Trust Network Access with Zscaler provides a strong security framework for modern organizations. By verifying every access request, limiting access to specific applications, and continuously monitoring user activity, the system effectively prevents unauthorized application access and strengthens the overall cybersecurity posture of the organization.

List of Vulnerability Table:

Practice Website:

S.No	Vulnerability Name	CWE - No
1	Inclusion of Sensitive Information in Source Code	CWE-540
2	Improper Restriction of XML External Entity Reference	CWE-611
3	Use of Unmaintained Third Party Components	CWE-1104
4	CWE-916 Use of Password Hash With Insufficient Computational Effort	CWE-916
5	Improper Neutralization of HTTP Headers for Scripting Syntax	CWE-644
6	Reliance on Untrusted Inputs in a Security Decision	CWE-807
7	Improper Verification of Source of a Communication Channel	CWE-940
8	Inclusion of Functionality from Untrusted Control Sphere	CWE-829

9	Information Loss of Omission	CWE-221
10	Improper Check for Unusual or Exceptional Conditions	CWE-754

REPORTS:

1) Vulnerability Name: Inclusion of Sensitive Information in Source Code

CWE/CVE: CWE-540

OWASP/SANS Category:

Description:

CWE-540 is a security weakness where sensitive information such as passwords, API keys, encryption keys, or database credentials is stored directly in the source code. If the source code is accessed by unauthorized users or shared publicly, attackers can easily obtain this confidential information and misuse it to access systems or data.

Business Impact:

- Attackers may gain unauthorized access to applications or databases.
- It can lead to data breaches and financial loss.
- The organization's reputation and customer trust may be affected.

CWE-540: Inclusion of Sensitive Information in Source Code
Weakness ID: 540
Vulnerability Mapping: ALLOWED
Abstraction: None

View customized information: Conceptual Operational Mapping Priority Complete Custom

Description
Source code on a web server or repository often contains sensitive information and should generally not be accessible to users.

Extended Description
There are situations where it is critical to remove source code from an area or server. For example, obtaining Perl source code on a system allows an attacker to understand the logic of the script and extract extremely useful information such as code bugs or logins and passwords.

Common Consequences

Impact	Details
Final Application Data	Scope: Confidentiality

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design; System Configuration	Recommendations include removing this script from the web server and moving it to a location not accessible from the Internet.

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	↻	538	Insertion of Sensitive Information into Externally-Accessible File or Directory
ParentOf	↻	531	Inclusion of Sensitive Information in Test Code

2) Vulnerability Name: Improper Restriction of XML External Entity Reference

CWE/CVE: CWE-611

OWASP/SANS Category:

Description

Improper Restriction of XML External Entity Reference (XXE) occurs when an application processes XML input without properly restricting external entity references. Attackers can exploit this vulnerability by sending malicious XML data that forces the server to access local files, internal systems, or external resources. This may lead to unauthorized access to sensitive information or allow attackers to perform server-side request forgery (SSRF).

Business Impact

This vulnerability can expose confidential data such as system files or internal network information. Attackers may use this data to gain further access to the system or disrupt services. For organizations, it can result in data breaches, operational risks, financial loss, and damage to reputation.

CWE-611: Improper Restriction of XML External Entity Reference

Weakness ID: 611

Vulnerability Mapping: ALLOWED

Abstraction: Data

View customized information:

Conceptual

Operational

Mapping

Priority

Complete

Custom

Description

The product processes an XML document that can contain XML entities with URIs that resolve to documents outside of the intended sphere of control, causing the product to embed incorrect documents into its output.

```
<DOCTYPE doc[
  <ENTITY %access SYSTEM "http://db.sample.com/resource"%>
  <tag %access />
]>
```

The diagram illustrates the attack flow: an attacker sends a malicious XML payload to a product. The product, which is labeled 'Product db.sample.com', then accesses sensitive information from an internal database. The attacker's goal is to cause the product to embed incorrect documents into its output.

Alternate Terms

XXE

An acronym used for the term "XML external Entities"

Common Consequences

Impact

Details

Scope: Confidentiality

If the attacker is able to include a crafted DTD and a default entity resolver is enabled, the attacker may be able to access arbitrary files on the system.

3) Vulnerability Name: Use of Unmaintained Third Party Components

CWE/CVE: CWE-1104

OWASP/SANS Category:

Description

This vulnerability occurs when an application uses third-party libraries or components that are no longer maintained or updated by their developers. These components may contain known security flaws, bugs, or compatibility issues that are not fixed because the software is outdated. Attackers can exploit these weaknesses to compromise the application or gain unauthorized access.

Business Impact

Using unmaintained components can expose the system to security risks and vulnerabilities. It may lead to data breaches, system compromise, or service disruptions. For organizations, this can cause financial losses, compliance issues, and damage to reputation if sensitive data or services are affected.

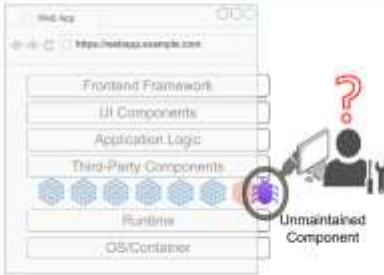
CWE-1104: Use of Unmaintained Third Party Components

Weakness ID: 1104
Vulnerability Mapping: ALLOWED
Abstraction: Basic

View customized information:

Description

The product relies on third-party components that are not actively supported or maintained by the original developer or a trusted proxy for the original developer.



Common Consequences

Impact	Details
Product Maintainability: Varies by Context	Scope: Other Relying on unmaintained components makes it difficult or impossible to fix significant bugs and vulnerabilities, can render code obsolete, and undermine security by introducing weaknesses and increasing the risk of new vulnerabilities.

4) Vulnerability Name: Use of Password Hash With Insufficient Computational Effort

CWE/CVE: CWE-916

OWASP/SANS Category:

Description

This vulnerability occurs when an application stores passwords using hashing algorithms that require very low computational effort, such as weak or outdated hashing methods. These hashes can be easily cracked by attackers using brute-force or dictionary attacks. As a result, attackers may recover the original passwords from the stored hashes.

Business Impact

If attackers successfully crack password hashes, they can gain unauthorized access to user accounts and sensitive systems. This may lead to data breaches, account compromise, and misuse of confidential information. For organizations, it can result in financial losses, security incidents, and damage to customer trust and reputation.

CWE-916: Use of Password Hash With Insufficient Computational Effort

Weakness ID: 916

Vulnerability Mapping: ALLOWED

Abstraction: Base

View contained information:

Conceptual

Operational

Mapping

Concepts

Custom

Description

The product generates a hash for a password, but it uses a scheme that does not provide a sufficient level of computational effort that would make password cracking attacks infeasible or expensive.

Extended Description

Many password storage mechanisms compute a hash and store the hash, instead of storing the original password in plaintext. In this design, authentication involves accepting an incoming password, computing its hash, and comparing it to the stored hash.

Many hash algorithms are designed to execute quickly with minimal overhead, even cryptographic hashes. However, this efficiency is a problem for password storage, because it can reduce an attacker's workload for brute-force password cracking. If an attacker can obtain the hashes through some other method (such as SQL injection on a database that stores hashes), then the attacker can store the hashes offline and use various techniques to crack the passwords by computing hashes efficiently. Without a built-in workload, modern attacks can compute large numbers of hashes, or even exhaust the entire space of all possible passwords, within a very short amount of time, using massively-parallel computing (such as cloud computing) and GPU, ASIC, or FPGA hardware. In such a scenario, an efficient hash algorithm helps the attacker.

There are several properties of a hash scheme that are relevant to its strength against an offline, massively-parallel attack:

- The amount of CPU time required to compute the hash ("stretching")
- The amount of memory required to compute the hash ("memory-hard" operations)
- Including a random value, along with the password, as input to the hash computation ("salting")
- Given a hash, there is no known way of determining an input (e.g., a password) that produces this hash value, other than by guessing possible inputs ("one-way" hashing)
- Relative to the number of all possible hashes that can be generated by the scheme, there is a low likelihood of producing the same hash for multiple different inputs ("collision resistance")

Note that the security requirements for the product may vary depending on the environment and the value of the passwords. Different schemes might not provide all of these properties, yet may still provide sufficient security for the environment. Conversely, a solution might be very strong in preserving one property, which still being very weak for an attack against another property, or it might not be able to significantly reduce the efficiency of a massively-parallel attack.

Common Consequences

- 5) Vulnerability Name: Improper Neutralization of HTTP Headers for Scripting Syntax
CWE/CVE: CWE-644
OWASP/SANS Category:

Description

This vulnerability occurs when an application does not properly sanitize or validate HTTP header values before processing them. Attackers can inject malicious scripting code into HTTP headers, which may be executed by the web application or the user's browser. This can lead to cross-site scripting (XSS) attacks or manipulation of application responses.

Business Impact

Exploitation of this vulnerability may allow attackers to steal sensitive information such as session cookies, user credentials, or personal data. It can also lead to unauthorized actions on behalf of users. For businesses, this may result in security breaches, loss of user trust, and potential legal or compliance issues.

CWE-644: Improper Neutralization of HTTP Headers for Scripting Syntax

Weakness ID: 644
Vulnerability Mapping: ALLOWED
Abstraction: None

View additional information:

Description

The product does not neutralize or incorrectly neutralizes web scripting syntax in HTTP headers that can be used by web browser components that can process raw headers, such as Flash.

Extended Description

An attacker may be able to conduct cross-site scripting and other attacks against users who have these components enabled.

If a product does not neutralize user controlled data being placed in the header of an HTTP response coming from the server, the header may contain a script that will get executed in the client's browser context, potentially resulting in a cross site scripting vulnerability or possibly an HTTP response splitting attack. It is important to carefully control data that is being placed both in HTTP response header and in the HTTP response body to ensure that no scripting syntax is present, taking various encodings into account.

Common Consequences

Impact	Details
Execute Unauthorized Code or Commands	Scope: Integrity, Confidentiality, Availability Run arbitrary code.
Read Application Data	Scope: Confidentiality Attackers may be able to obtain sensitive information.

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design	

6) Vulnerability Name: Reliance on Untrusted Inputs in a Security Decision

CWE/CVE: CWE-807

OWASP/SANS Category:

Description

This vulnerability occurs when an application makes security-related decisions based on input received from untrusted sources, such as user input, client-side data, or external systems. If the application does not properly validate or verify this input, attackers may manipulate the data to bypass security controls or gain unauthorized access.

Business Impact

Exploiting this vulnerability can allow attackers to bypass authentication, access restricted resources, or perform unauthorized actions within the system. This may lead to data breaches, system misuse, and loss of sensitive information. For organizations, it can result in financial losses, operational risks, and damage to reputation.

CWE-807: Reliance on Untrusted Inputs in a Security Decision

Weakness ID: 807

Vulnerability Mapping: ALLOWED

Abstraction: None

View customized information:

Conceptual

Operational

Mapping

Complete

Custom

Description

The product uses a protection mechanism that relies on the existence or values of an input, but the input can be modified by an untrusted actor in a way that bypasses the protection mechanism.

Extended Description

Developers may assume that inputs such as cookies, environment variables, and hidden form fields cannot be modified. However, an attacker could change these inputs using customized clients or other attacks. This change might not be detected. When security decisions such as authentication and authorization are made based on the values of these inputs, attackers can bypass the security of the software.

Without sufficient encryption, integrity checking, or other mechanism, any input that originates from an outsider cannot be trusted.

Common Consequences

Impact

Bypass Protection

Mechanism: Gain

Privileges or

Assume Identity:

Varies by Context

Details

Scope: Confidentiality, Access Control, Availability, Other

Attackers can bypass the security decision to access whatever is being protected. The consequences will depend on the associated functionality, but they can range from granting additional privileges to untrusted users to bypassing important security checks. Ultimately, this weakness may lead to exposure or modification of sensitive data, system crash, or execution of arbitrary code.

Potential Mitigations

Phase(s)

Architecture and

Design

Mitigation

Strategy: Attack Surface Reduction

Store state information and sensitive data on the server side only.

Ensure that the system definitively and unambiguously keeps track of its own state and user state and has rules defined for legitimate

state transitions. Do not allow any application code to affect state directly in any way other than through legitimate actions leading to state

- 7) Vulnerability Name: Improper Verification of Source of a Communication Channel
CWE/CVE: CWE-940
OWASP/SANS Category:

Description

This vulnerability occurs when an application fails to properly verify the source of a communication channel before accepting or processing data. If the system does not authenticate the sender or validate the communication source, attackers may impersonate trusted entities and send malicious or unauthorized data to the application.

Business Impact

Exploitation of this vulnerability can allow attackers to perform unauthorized actions, intercept sensitive data, or manipulate communications between systems. This may lead to security breaches, data compromise, and service disruption. For organizations, it can cause financial loss, operational impact, and damage to reputation.

CWE-940: Improper Verification of Source of a Communication Channel

Weakness ID: 940
Vulnerability Mapping: ALLOWED
Abstraction: Basic

View customized information:

Description
The product establishes a communication channel to handle an incoming request that has been initiated by an actor, but it does not properly verify that the request is coming from the expected origin.

Extended Description
When an attacker can successfully establish a communication channel from an untrusted origin, the attacker may be able to gain privileges and access unexpected functionality.

Common Consequences

Impact	Details
Gain Privileges or Assume Identity; Varies by Context; Bypass Protection Mechanism	Scope: Access Control, Other An attacker can access any functionality that is inadvertently accessible to the source.

Potential Mitigations

Phase(s)	Mitigation
Architecture and Design	Use a mechanism that can validate the identity of the source, such as a certificate, and validate the integrity of data to ensure that it cannot be modified in transit using an Adversary-in-the-Middle (AITM) attack. When designing functionality of actions in the URL scheme, consider whether the action should be accessible to all mobile applications, or if an allowlist of applications to interface with is appropriate.

8) Vulnerability Name: Inclusion of Functionality From Untrusted Control Sphere

CWE/CVE: CWE-829

OWASP/SANS Category:

Description

This vulnerability occurs when an application includes or executes code, libraries, or resources from an untrusted or external source without proper validation. If these external components are malicious or compromised, they can introduce harmful functionality into the application. This may allow attackers to execute unauthorized code or manipulate the behavior of the system.

Business Impact

Exploiting this vulnerability can lead to unauthorized code execution, data manipulation, or system compromise. It may expose sensitive information or allow attackers to control parts of the application. For organizations, this can result in security incidents, data breaches, financial losses, and damage to reputation.

CWE-829: Inclusion of Functionality from Untrusted Control Sphere

Weakness ID: 829
 Vulnerability Mapping: **ALLOWED**
 Abstraction: Low

View additional information: Conceptual Operational Mapping Priority Complete Custom

Description

The product imports, requires, or includes executable functionality (such as a library) from a source that is outside of the intended control sphere.

Common Consequences

Impact	Details
Execute Untrusted Code or Commands	Scope: Confidentiality, Integrity, Availability An attacker could insert malicious functionality into the program by causing the program to download code that the attacker has placed into the untrusted control sphere, such as a malicious web site. This could enable the injection of malware, information exposure by granting excessive privileges or permissions to the untrusted functionality, DOM-based XSS vulnerabilities, stealing user's cookies, open redirect to malware (CWE-601).

9) Vulnerability Name: Information Loss or Omission

CWE/CVE: CWE-221

OWASP/SANS Category:

Description

This vulnerability occurs when important information is omitted or not properly included during data processing, storage, or transmission. Missing critical data elements can lead to incorrect system behavior, inaccurate records, or incomplete security checks. Attackers may exploit such omissions to manipulate system operations or bypass controls.

Business Impact

Information loss due to omission can result in inaccurate decision-making, data integrity issues, and security weaknesses. It may affect system reliability and cause operational problems. For organizations, this can lead to financial loss, compliance issues, and reduced trust in the system.

CWE-221: Information Loss or Omission

Weakness ID: 221
Vulnerability Mapping: ALLOWED (with careful review of mapping notes)
Abstraction: Class

View customized information:

Description

The product does not record, or improperly records, security-relevant information that leads to an incorrect decision or hampers later analysis.

Common Consequences

Impact **Details**
Info Activities: Stages: Non Repudiation

Relationships

Relevant to the view "Research Concepts" (View-1000)

Nature	Type	ID	Name
ChildOf	PI	664	Improper Control of a Resource Through its Lifetime
ParentOf	U	222	Truncation of Security-relevant Information
ParentOf	U	223	Omission of Security-relevant Information
ParentOf	U	224	Obscured Security-relevant Information by Alternate Name
ParentOf	U	356	Product UI does not Warn User of Unsafe Actions
ParentOf	U	396	Declaration of Catch for Generic Exception
ParentOf	U	397	Declaration of Throws for Generic Exception
ParentOf	U	451	User Interface (UI) Misrepresentation of Critical Information

Modes Of Introduction

Phase **Note**

10) Vulnerability Name: Check for unusual or Exceptional Conditions

CWE/CVE: CWE-754

OWASP/SANS Category:

Description

This vulnerability occurs when an application does not properly handle unusual or unexpected conditions such as invalid inputs, system errors, or unexpected states. Without proper checks and error handling, the system may behave unpredictably or expose sensitive information. Attackers may exploit these situations to bypass security controls or cause system failures.

Business Impact

Failure to handle exceptional conditions can lead to system crashes, data corruption, or exposure of sensitive information. It may also allow attackers to exploit weaknesses in the system. For organizations, this can result in service disruptions, security risks, and potential financial or reputational damage.

CWE-754: Improper Check for Unusual or Exceptional Conditions

Weakness ID: 754
Vulnerability Mapping: **ALLOWED** (with careful review of mapping notes)
Abstraction: Close

View customized information: Conceptual Operational Mapping Friendly Complete Custom

Description
The product does not check or incorrectly checks for unusual or exceptional conditions that are not expected to occur frequently during day to day operation of the product.

Extended Description
The programmer may assume that certain events or conditions will never occur or do not need to be worried about, such as low memory conditions, lack of access to resources due to restrictive permissions, or misbehaving clients or components. However, attackers may intentionally trigger these unusual conditions, thus violating the programmer's assumptions, possibly introducing instability, incorrect behavior, or a vulnerability.
Note that this entry is not exclusively about the use of exceptions and exception handling, which are mechanisms for both checking and handling unusual or unexpected conditions.

Common Consequences

Impact	Details
(DoS) Crash, DoS, or Restore / Unexpected State	Scope: Integrity, Availability The data which were produced as a result of a function call could be in a bad state upon return. If the return value is not checked, then this bad data may be used in operations, possibly leading to a crash or other unintended behaviors.

Potential Mitigations

Phase(s)	Mitigation
Requirements	Strategy: Language Selection Use a language that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. Choose languages with features such as exception handling that force the programmer to anticipate unusual conditions that may generate exceptions. Custom exceptions may need to be developed to handle unusual business-logic conditions. Be careful not to pass sensitive

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- <http://testfire.net/>

Target ip address:- 65.61.137.117

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing From HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact: -Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Non-compliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol

Deprecated

Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1. As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus $\leq$ 1024 Bits (Logjam)

Severity: - LOW

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure

Severity: - INFO

Plugin: - 10114

Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact: -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

5) Vulnerability Name: - 46180 - Additional DNS

Hostnames Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com [192.0.32.10]

Business Impact: -This does not pose an immediate threat to business operations or data security. It indicates the discovery of hostnames that are associated with the remote host, particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk on its own, it could be useful for understanding the server's configuration and infrastructure. Organizations should consider this information as part of their network documentation but do not need to take immediate action to mitigate it as a security threat.

6) Vulnerability Name: - 39446 - Apache Tomcat

Detection Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Business Impact: -Is an informational finding that identifies the presence of a remote Apache Tomcat web server. While this information itself does not indicate a security threat or impact on business operations, it can be useful for network administrators and security professionals to be aware of the technologies in use on their network. Understanding the presence of an Apache Tomcat server can be valuable for maintaining and securing web applications, but it does not require immediate action to mitigate a security risk.

7) Vulnerability Name: - 45590 - Common Platform Enumeration
(CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

Business Impact: - This provides insights into hardware and software products identified on a host through a Nessus scan. It reports CPE matches, which are standardized identifiers for these products. This information is valuable for asset management and inventory purposes. While it doesn't signify a security threat, it aids administrators in understanding the components within their network, contributing to effective resource management and facilitating future system maintenance.

8)Vulnerability Name : 45590 – Common Plateform Enumeration(CPE)

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Solution: -

Business Impact: - It allows for the identification of the remote system type, such as a printer, router, or general-purpose computer, based on the remote operating system. While this doesn't pose a direct security threat, it offers valuable insights for network administrators to better understand and classify the devices in their network. This information aids in network management, optimization, and ensures that the right security measures are in place for each device type.

9)Vulnerability Name: - 84502 - HSTS Missing From HTTPS

Server Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS.

Business Impact: -Indicates that the remote HTTPS server does not enforce HTTP Strict Transport Security (HSTS). HSTS is a crucial security feature that, when configured on the server, instructs web browsers to communicate exclusively via HTTPS, enhancing security. The absence of HSTS potentially exposes the server to downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens protections against cookie hijacking, posing risks to data confidentiality and user security. Enabling HSTS is essential to ensure a higher level of protection for data transmitted between clients and the server.

10)Vulnerability Name: - 10107 - HTTP Server Type and
Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Business Impact: -This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

Stage – 3

Report: -

Title: - Implementing Zero Trust Network Access (ZTNA) with Zscaler: Preventing Unauthorized Access.”

Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is a security model that provides safe remote access to an organization’s internal applications and data. It works based on strict access control policies. Unlike traditional VPNs, which allow users to access the entire network, ZTNA follows the principle “**never trust, always verify.**”

In this approach, users are allowed to access only the specific applications they need. Before giving access, the system verifies the user’s identity and checks whether the device is secure. This helps prevent unauthorized users from accessing sensitive applications.

ZTNA is an important part of modern cybersecurity. It hides internal applications from the internet and creates secure encrypted connections between users and applications. This reduces security risks and prevents common cyber attacks such as unauthorized access and lateral movement inside the network.

- **The ZTNA Access Cycle**

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy for every access request. It typically consists of the following steps:

1. **User Request:** A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an internal code repository).
2. **Identity and Device Verification:** Before any connection is established, the ZTNA solution verifies who the user is (via multi-factor authentication, or MFA) and checks the security posture of their device. This includes ensuring the device has up-to-date antivirus, a healthy firewall, and is not compromised.
3. **Policy Enforcement:** The ZTNA solution checks the access policy. Does this specific user, with this specific device, have permission to access the requested application at this specific time?
4. **Establish Secure Connection:** If the policy allows access, the ZTNA solution creates a highly secure, encrypted micro-tunnel between the user's device and the target application. Crucially, the user never gains access to the underlying network, only to the application itself.
5. **Continuous Monitoring:** The ZTNA solution continues to monitor the connection for anomalies. If the user's behavior becomes suspicious or their device posture changes, the connection can be terminated in real-time.
6. **Logging and Analytics:** All access attempts, successful and failed, are logged and
7. analyzed. This data is used for auditing, threat hunting, and refining access policies.

Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-based security platform that helps organizations securely access applications and protect their network. It delivers security services from the cloud, so there is no need for traditional hardware such as VPN devices.

For **Zero Trust Network Access (ZTNA)**, Zscaler provides **Zscaler Private Access (ZPA)**. This service allows users to securely access private applications without giving them full access to the internal network. Access is provided based on **user identity, device security, and defined access policies**, which helps prevent unauthorized application access.

Zscaler works on a simple concept: the internal application is connected to the Zscaler cloud, and authorized users securely access it through the cloud. To make access decisions and improve security, Zscaler collects information from different sources such as:

1. **Identity Providers (IdP)** – Services like Azure AD or Ping Identity are used to verify the user's identity before allowing access.
2. **Device Security Tools** – Tools such as CrowdStrike or Microsoft Defender check whether the user's device is secure and meets security requirements.
3. **Business Applications** – These include internal applications like web portals, file servers, and other systems hosted in data centers or cloud platforms.
4. **Zscaler App Connectors** – These are small software components installed in the data center or cloud that create secure connections to the Zscaler cloud and hide internal servers from the public internet.

Policy Enforcement in Zscaler

Using the collected security data, **Zscaler** enforces strict access policies to protect applications and prevent unauthorized access in a **Zero Trust Network Access (ZTNA)** environment.

The main policy controls include:

1. **Identity-Based Access** – Access policies are based on the user's identity or group (such as students, faculty, or staff) instead of relying only on IP addresses.
2. **Application Segmentation** – Users are allowed to access only the specific applications they need, rather than gaining access to the entire internal network or subnet.
3. **Least Privilege Access** – Users are given only the minimum level of access required to perform their tasks, which helps reduce security risks and prevents unauthorized activities.

The Zscaler ZTNA Cycle

The **Zscaler Private Access ZTNA cycle** shows how **Zscaler** applies the principles of **Zero Trust Network Access (ZTNA)** to provide secure access to internal applications through the cloud. The main steps are:

1. **User Login and Authentication** – A user tries to access an internal application. The user is redirected to the organization's Identity Provider for authentication and Multi-Factor Authentication (MFA).
2. **Device Posture Check** – Zscaler checks the security status of the user's device using integrated security tools to ensure it follows the organization's security policies.
3. **Policy Verification** – The Zscaler cloud checks the access request against security policies to confirm whether the user, device, and other factors such as location and time are authorized.
4. **Secure Micro-Tunnel Creation** – If the request is approved, Zscaler creates a secure encrypted connection between the user's device and the specific application using the Zscaler Client Connector and App Connector.
5. **Traffic Inspection** – Zscaler can optionally inspect the traffic for security threats, data loss prevention (DLP), or malware detection.

6. **Logging and Analytics** – All user activities and access attempts are recorded in the Zscaler cloud portal for monitoring, reporting, and security analysis.

MISP Integration

Malware Information Sharing Platform (MISP) can be integrated with **Zscaler** to improve security in a **Zero Trust Network Access (ZTNA)** environment.

1. **Threat Intelligence Feed** – MISP shares information about malicious IPs, domains, and URLs with Zscaler.
2. **Proactive Blocking** – If a user tries to access a malicious website, **Zscaler Internet Access (ZIA)** can automatically block it.
3. **Better Visibility** – Security teams can compare MISP data with Zscaler logs to identify suspicious activities.

College Network Infrastructure

A college network usually includes routers, switches, wireless access points, firewalls, IDS, and internal application servers such as student portals and research systems.

Currently, many colleges use VPN for remote access. However, VPN provides **broad network access**, which can create security risks if a device is compromised.

Deploying ZTNA Using Zscaler

To deploy **Zscaler Private Access (ZPA)** in a college:

1. Identify internal applications that need secure access.
2. Create user groups such as students, faculty, and staff.
3. Configure Zscaler policies to allow users to access only the applications they need.

Plan for Deploying ZTNA using Zscaler

To implement **Zscaler Private Access (ZPA)** in a college network using **Zero Trust Network Access (ZTNA)**, the plan includes the following steps:

1. **Application Discovery** – Identify all internal applications such as ERP systems, library portals, research servers, and file-sharing services that are currently accessed through VPN.
2. **User Segmentation** – Divide users into groups like students, faculty, IT staff, and external collaborators, and determine which applications each group needs.
3. **Deploy Zscaler App Connectors** – Install App Connectors in the college data center so that internal applications can securely connect to the Zscaler cloud while remaining hidden from the public internet.
4. **Integrate Identity Provider** – Connect Zscaler with the organization's identity provider such as Microsoft Azure AD to use existing login credentials and Multi-Factor Authentication.
5. **Configure Access Policies** – Create access rules in the Zscaler portal to control which users can access specific applications.
6. **Deploy Zscaler Client Connector** – Install the client connector on user devices so that traffic to private applications is securely routed through Zscaler.

Threat Intelligence in Zscaler ZTNA

In **Zscaler** and **Zero Trust Network Access (ZTNA)**, threat intelligence helps identify **who is accessing applications, from where, and whether the activity is risky**. It provides better security by analyzing user behavior and access patterns.

Sources of Threat Intelligence

1. **Zscaler Cloud Logs** – Provide real-time information about user access, including which applications are accessed, device details, and location.
2. **External Threat Feeds** – Platforms like **Malware Information Sharing Platform (MISP)** provide information about malware, phishing attacks, and malicious servers.

3. **Identity Provider Logs** – Login records from identity providers help detect unusual login attempts, such as a user logging in from different locations within a short time.

Uses of Threat Intelligence

1. **Adaptive Access Control** – If a login attempt comes from a risky location, Zscaler can require additional verification or block the access request.
2. **Detecting Compromised Accounts** – Security teams can analyze Zscaler logs to identify unusual behavior, such as users accessing applications they normally do not use.
3. **Blocking Malicious Traffic** – **Zscaler Internet Access (ZIA)** can block connections to known malicious websites and protect users from cyber threats.

Incident Response in ZTNA (Using Zscaler)

Incident response in a **Zero Trust Network Access (ZTNA)** environment using **Zscaler** is faster and more controlled because access is limited to specific applications.

1. **Detection** – The security team detects suspicious activity using Zscaler logs, such as unusual data downloads or login behavior.
2. **Containment** – The user or device can be quickly blocked in the Zscaler portal to stop unauthorized access.
3. **Eradication** – The infected device is scanned and cleaned to remove malware.
4. **Recovery** – After fixing the issue and resetting credentials, access is safely restored.
5. **Review** – Security teams analyze logs and update policies to prevent similar attacks in the future.

Benefits of ZTNA Incident Response

Using **Zscaler** in a **Zero Trust Network Access (ZTNA)** environment provides several benefits:

1. **Fast Containment** – Security teams can quickly block users or devices through the cloud dashboard.
2. **No Lateral Movement** – Attackers cannot move to other systems because access is limited to specific applications.
3. **Better Investigation** – Zscaler provides detailed logs of all user activities for easier analysis.
4. **Compliance Support** – Helps organizations protect sensitive data and meet security regulations.

Understanding the Tool – Zscaler ZPA

Zscaler Private Access (ZPA) is a cloud service that follows the ZTNA principle of **connecting users directly to applications instead of the entire network.**

Key features include:

1. **Application-Based Access** – Access policies are defined for specific applications rather than the entire network.
2. **Hidden Network** – Internal servers remain hidden from the internet, reducing attack risks.
3. **Secure Access** – Applications become visible only after proper authentication and verification.
4. **Better User Experience** – Users can access applications easily without complex VPN connections.
5. **Scalability** – Being cloud-based, ZPA can support many users without needing additional hardware.

Conclusion

Stage 1:

In the first stage, the concept of **Zero Trust Network Access (ZTNA)** was introduced. It explains the importance of verifying user identity and device security before allowing access to internal applications.

Stage 2:

The second stage focused on understanding how **Zscaler** implements ZTNA using **Zscaler Private Access (ZPA)**. It demonstrated how users are connected directly to applications through secure encrypted connections instead of giving full network access like traditional VPNs.

Stage 3:

The final stage explained the deployment and benefits of ZTNA with Zscaler in an organization. It showed how identity-based access, application segmentation, and continuous monitoring help prevent unauthorized application access and improve overall cybersecurity.

Considering the future scope,

Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope: -

Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable

Here are some of the key trends that are expected to shape the future of the testing process:

- **Increased focus on continuous testing:** Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- **Rise of AI and ML:** AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- **Shift to cloud-based testing:** Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- **Increased focus on testing automation:** Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future

scope of SOC / SEIM:-

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. **AI-Driven Zero Trust (AI-ZTA):** Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.
2. **Integration with Edge Computing and IoT:** As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.
3. **Identity-Centric Everything:** The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including **continuous behavioral biometrics** (keystroke dynamics, gait analysis) and **decentralized identity** solutions using blockchain, ensuring that the user behind the session is verified at all times.

Convergence with SASE Architecture: Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location

4. **Zero Trust for Operational Technology (OT) and Critical Infrastructure:** Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical infrastructure. Future scope includes air-gapped Zero

Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.

5. **Automated Threat Hunting and Response:** Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, isolate affected systems, and even roll back malicious changes.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: -

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END

